

The Two-Person Rule for AI Agents: Fail-Closed Multi-Party Authorization with Offline-Verifiable Receipts

Iman Schrock (EMILIA Protocol, Inc.; team@emiliaprotocol.ai)

20 June 2026

Abstract

Autonomous agents increasingly hold credentials sufficient to perform irreversible operations: releasing payments, changing beneficiary records, rotating production credentials, deleting data. Existing controls authenticate and authorize *sessions and scopes*; they do not answer the question that matters at the moment of execution — *should this exact action happen, and which accountable humans said yes?* We present EP-QUORUM, a multi-party authorization mechanism that ports the two-person rule — the control that governs nuclear release and large-value treasury movement — to AI-agent actions. EP-QUORUM binds a set of pairwise-distinct, accountable human approvers, each holding their own device-bound signing key, to one exact action, such that the action is authorized only when a fail-closed predicate over all of their signatures holds. The predicate enforces all-signatures-valid, action-binding, separation of duties (distinct humans), role admission, an M-of-N threshold, an optional total order, and a bounded approval window. Each quorum member is an unmodified single-approver authorization receipt over the same action hash, so the construction is additive: a single-approver policy is the degenerate one-member case, and the existing offline receipt verifier is reused per member. We give the predicate, an incremental server-side admission rule that keeps a non-conforming signer out of the trail before it is recorded, and an adversarial conformance suite of nine vectors that three independent implementations (JavaScript, Python, Go) are required to agree on. We are deliberate about limitations: a quorum raises the cost of unilateral action and makes every approval attributable, but it does not defeat collusion among the required number of humans, an enrollment that lets one human hold multiple identities, or simultaneous coercion — and we argue that honesty about these boundaries is a security property, not a caveat.

1. Introduction

The deployment of AI agents with real operational authority creates a specific, under-addressed risk: an agent that is authenticated and authorized *in general* can nonetheless take a *specific* irreversible action that no human intended or reviewed. Identity and access management answers “is this actor allowed to operate in this system?”; it does not answer “should this particular wire, to this beneficiary, for this amount, execute now?” Fraud and error that occur inside a valid session — a prompt-injected agent, a compromised credential, a business-email-compromise-style instruction — are invisible to session-level controls.

The single-approver EMILIA Protocol (EP) authorization receipt [1] addresses this by requiring a named human to sign the exact action with a key the orchestrating operator does not hold,

producing an artifact that is verifiable offline and consumable exactly once. But for the highest-stakes actions, a single approver is the wrong unit of control. The discipline that governs the most consequential decisions in finance, government, and weapons handling is the *two-person rule*: no single individual, regardless of seniority or authentication strength, can unilaterally cause the action; two or more distinct, accountable people must each independently authorize.

This paper specifies EP-QUORUM, which expresses the two-person rule — and its generalizations to M-of-N and to ordered approval chains — as a cryptographic predicate over EP signoffs. Our contributions are:

1. **A fail-closed multi-party authorization predicate** (Section 4) that composes single-approver receipts into a quorum without introducing any new signature type or signing ceremony, and that is computable offline from the receipt and policy alone.
2. **An incremental admission rule** (Section 5) that enforces the predicate as each approver signs — rejecting a wrong-action, wrong-role, duplicate, out-of-order, stale, or invalid signer *before* it enters the trail — while requiring the executing system to nonetheless re-check the full predicate, because it does not trust the orchestrator.
3. **An adversarial conformance suite** (Section 6) of nine vectors carrying real WebAuthn assertions, against which three independent implementations are required to agree, separating “too strict” failures (denying valid quorums) from the security-critical “too lenient” failures.
4. **An explicit threat model and limitation statement** (Sections 3, 7) that states what multi-party authorization does *not* prevent.

2. Background and Related Work

Single-approver authorization receipts. EP-QUORUM is a profile of the EP authorization receipt [1], which binds one approver to one action via a user-verification-gated WebAuthn signature over a canonical Authorization Context (action hash, policy reference, nonce, validity window). Receipts are Merkle-anchored and verifiable fully offline, and the protocol enforces one-time consumption and separation of duties (an initiator must not approve its own action). Safety properties of the single-approver state machine are maintained as machine-checked TLA+ and Alloy models.

Threshold and multisignature cryptography. Threshold signatures and multisig wallets (e.g., in distributed key generation and blockchain custody) also require k -of- n parties to act. EP-QUORUM differs in intent and verification surface: it does not aggregate keys into one signature, and it deliberately preserves *per-approver attribution* — the receipt records which named human signed, in which role, at what time, over exactly which action, each independently verifiable. The goal is accountability and offline audit, not key aggregation; threshold cryptography optimizes the opposite (hiding the signer set behind one key).

Human-in-the-loop and dual control. Dual-control and maker-checker patterns are standard in banking software, but are typically enforced inside a mutable application database controlled by the very operator whose conduct an auditor would examine. EP-QUORUM moves the evidence outside that trust boundary: each approval is a device-held signature the operator cannot forge, and the satisfied/not-satisfied judgment is reproducible by any third party.

Backchannel authentication (CIBA), workload identity (WIMSE), delegation receipts. These authenticate the agent, transport an approval, or bind a user’s delegation; they are complementary layers and do not produce an action-bound, offline-verifiable, multi-party-quorum artifact. EP-QUORUM composes with them by reference.

3. Threat Model

We consider an agent acting in an environment with the following adversaries.

- **Compromised or misaligned initiator.** The agent may be prompt-injected, jailbroken, or simply wrong. It can propose any action and any justification. We assume it cannot produce an approver’s device-held signature.
- **Compromised orchestrating operator.** The party running the policy registry, routing, and log may be malicious or breached. Per the base protocol it is *not* in the signing trust path: it can deny service and fail to route, but cannot forge an approver’s signature. EP-QUORUM additionally assumes the executing system re-verifies the quorum predicate rather than trusting the operator’s “approved” assertion.
- **Single compromised approver.** One approver’s device, credential, or person may be compromised or coerced. The two-person rule is precisely the control that renders one such compromise insufficient.

We treat as **out of scope / explicitly not prevented**: collusion among the full required set of distinct approvers; one human controlling multiple enrolled identities (an enrollment-time control, not a runtime one); simultaneous coercion of a complete quorum; and presentation attacks in which an approver signs a faithful-looking but misleading rendering (mitigated, not eliminated, by the base protocol’s rendering-fidelity controls). Section 7 states these in full.

4. The Quorum Predicate

A **Quorum Policy** declares the approval mode (`threshold` or `ordered`), the required count k , a roster of eligible (`role`, `approver`) slots, a `distinct_humans` flag (default true), and an approval window `window_sec` (default 900). A **member** is a triple (`role`, `approver_public_key`, `signoff`) where the signoff is an unmodified EP signoff — an Authorization Context plus its WebAuthn assertion — over the action.

A trail of members is a **satisfied quorum** for action hash H under policy P if and only if all of the following hold; a verifier returns “satisfied” only when every check passes and “not satisfied” on the first failure, on a malformed policy or member, or on any unrecognized condition:

1. **Well-formed policy.** Recognized mode, integer `required` ≥ 1 , non-empty roster.
2. **All signatures valid.** Each member’s WebAuthn assertion verifies against its `approver_public_key`, with the assertion challenge equal to the member’s context hash and user verification asserted. One invalid member fails the quorum.
3. **Action binding.** Every member’s context carries `action_hash` = H .
4. **Role admission.** Every member’s (`role`, `approver`) is on the roster.
5. **Distinct humans.** Under `distinct_humans`, approvers are pairwise distinct and distinct from the initiator.
6. **Threshold.** At least `required` admitted members exist.
7. **Order (ordered mode).** The i -th member matches the i -th roster slot; signature times are strictly increasing.
8. **Window.** Every member’s `issued_at` is within `window_sec` of the first member’s.

The predicate is a pure function of (P , H , `members`). Because each member is an unmodified single-approver receipt, check 2 is exactly the base verifier invoked per member; EP-QUORUM adds the set-level checks (1, 3–8). The same function is computed by the operator before consumption and by an independent executor or auditor offline — they cannot disagree on a correct input.

Why fail-closed. The dangerous failure in a multi-party gate is to treat ambiguity as approval. We specify the predicate so that absence of evidence, an unparseable member, a partial trail, or any single failed check yields “not satisfied,” never “satisfied.” This is the multi-party generalization of the single-approver rule that a partial or missing signoff authorizes nothing.

5. Incremental Admission

Evaluating the full predicate only at execution time wastes the opportunity to reject a bad signer early and produces confusing partial trails. EP-QUORUM therefore specifies an incremental admission rule evaluated before each new signoff is recorded: given P , H , the existing trail, and one candidate, it admits the candidate only if the action binds, the (**role**, **approver**) is on the roster, no admitted member shares the candidate’s human (under **distinct_humans**), the candidate matches the next slot in ordered mode, the time is within window (and strictly increasing in ordered mode), and the signature verifies — otherwise it rejects with a specific reason (**action_mismatch**, **ineligible_role**, **duplicate_human**, **out_of_order**, **window_exceeded**, **non_increasing_time**, **invalid_signature**).

Crucially, incremental admission is an enforcement convenience, **not** a substitute for the predicate. The executing system re-evaluates the full quorum gate over the assembled trail before acting, because it does not trust the orchestrator to have admitted honestly. This mirrors the base protocol’s execution-side enforcement: the strongest deployment places verification at the system of record, which refuses to act on an unsatisfied quorum no matter what the operator asserts.

6. Conformance and Implementation

We maintain an adversarial conformance suite, EP-QUORUM-v1, of nine vectors that each carry real Class-A WebAuthn (ES256) assertions:

Vector	Expect	Exercises
<code>accept_ordered_3of3</code>	satisfied	Ordered PO -> AO -> IG, distinct, increasing time
<code>accept_threshold_2of3</code>	satisfied	Any 2 distinct of 3
<code>reject_under_threshold</code>	not satisfied	Fewer than required
<code>reject_duplicate_human</code>	not satisfied	One human, two slots
<code>reject_out_of_order</code>	not satisfied	Out of roster order
<code>reject_action_mismatch</code>	not satisfied	Member bound to a different action
<code>reject_expired_window</code>	not satisfied	Member outside window
<code>reject_one_bad_signature</code>	not satisfied	One invalid signature
<code>reject_wrong_role</code>	not satisfied	Valid signature, off-roster approver

The suite is run against three independent implementations — JavaScript, Python, and Go — which are required to agree on every vector; divergence is a conformance defect. The “accept” vectors guard against an over-strict verifier (denying valid quorums); the “reject” vectors guard the security-critical direction (a verifier that accepts something it must not). The mechanism is implemented in the EP reference codebase: a pure predicate (**quorumGate**) and incremental admission rule (**canAccept**), wired into the live device-signature authorization path, and exercised end-to-end with multiple virtual WebAuthn authenticators (one per approver) to confirm that an action is blocked until the full ordered trail signs and is then permitted.

The reuse of the single-approver verifier per member is what makes cross-language agreement tractable: the hardest part — WebAuthn assertion verification and canonical context hashing — is the base protocol’s already cross-checked code, and EP-QUORUM’s additions are set-level integer and identity checks.

7. Limitations and Security Considerations

We state plainly what a satisfied quorum does and does not establish.

It proves: k pairwise-distinct enrolled approvers each produced a valid, action-bound, in-window, in-order (where required) signature with their own device-held keys, and the orchestrator forged none of them.

It does not prevent: (a) **Collusion** among the required number of distinct humans — a k -person rule stops $k-1$ bad actors, not k . (b) **One human, many identities** — if enrollment lets a single person hold multiple approver identifiers, distinctness is satisfied formally but not in substance; this is an enrollment-time control (directory authority, identity proofing), out of scope for the runtime predicate. (c) **Simultaneous coercion** of a full quorum. (d) **Presentation attacks** — an approver who signs a faithful-looking but misleading rendering produces a valid signature over the wrong understanding; the base protocol mitigates this with rendering-fidelity and second-surface controls but cannot eliminate it with cryptography. (e) **Diffusion of responsibility** — adding signers can *reduce* scrutiny if each assumes another is the careful one; quorum policies must be scoped to genuinely high-stakes, low-frequency actions, and deployments should monitor per-role time-to-sign and deny rates.

What EP-QUORUM converts these residual risks into is *attribution*: every approval is named, signed, role-tagged, time-stamped, and action-bound, so an abuse is evidenced rather than deniable. We regard the explicit statement of these boundaries as a security property — the most common failure in this category is a system that claims to make fraud impossible and thereby discourages the compensating controls that actually constrain it.

8. Conclusion

EP-QUORUM shows that the two-person rule, a centuries-old human-governance control, can be expressed for AI-agent actions as a small, fail-closed, offline-verifiable predicate over per-approver device signatures — additive over single-approver receipts, cross-language conformance-tested, and honest about its limits. As organizations move to grant agents real authority, the ability to require that no single party — human or machine — can unilaterally cause an irreversible action, while keeping every authorization independently auditable, is a prerequisite for doing so safely.

References

- [1] I. Schrock, “Authorization Receipts for High-Risk Agent Actions (EP),” Internet-Draft draft-schrock-ep-authorization-receipts, 2026.
- [2] W3C, “Web Authentication: An API for accessing Public Key Credentials, Level 2.”
- [3] A. Rundgren et al., “JSON Canonicalization Scheme (JCS),” RFC 8785, 2020.
- [4] S. Bradner, “Key words for use in RFCs to Indicate Requirement Levels,” BCP 14 / RFC 2119; B. Leiba, RFC 8174.

Artifacts: protocol drafts, the EP-QUORUM-v1 conformance vectors, and the three reference implementations are available in the EMILIA Protocol open-source repository (Apache-2.0). Site: <https://www.emiliaprotocol.ai>